DeBug : A Decentralised Bug-Bounty Platform

Inhouse Project

Major Project II

Review 1

Domain: Blockchain

Sustainable Development Goal:

- **Decent Work and Economic Growth**
- **Industry, Innovation, and Infrastructure**

V.E.S.
SINCE 1962

Group Number : **19**

Group Members :

Rohit Shahi [D17C/58]
Gopal Vanjarani [D17C/66]
Gaurav Mahadeshwar [D17C/43]
Umesh Tolani [D17C/64]

Project Mentor :

Ms. Geocey Shejy

Content

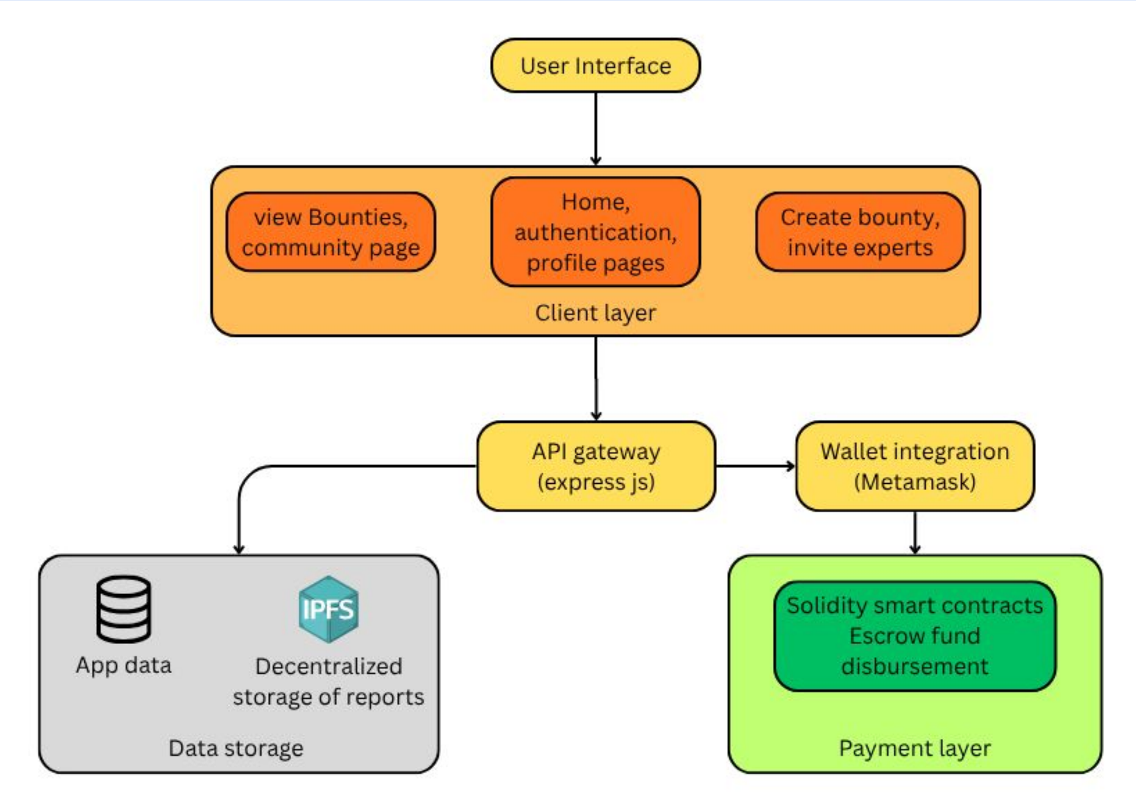
Introduction to Project

DeBug is an innovative decentralized bug-bounty platform that aims to build a transparent, trustworthy, and scalable ecosystem for security vulnerability reporting and reward distribution. By leveraging blockchain technology, it eliminates custodial risks, opaque payouts, and privacy concerns found in traditional platforms. DeBug follows a hybrid model—its on-chain Layer-2 components manage escrow, payouts, and dispute resolution, while off-chain web services handle authentication, encrypted submissions, notifications, and researcher reputation. This integration ensures verifiable payouts, researcher anonymity, and reputation portability across platforms. Designed for security researchers, software organizations, startups, and open-source communities, DeBug creates a fair, secure, and efficient environment for ethical vulnerability disclosure and collaboration.

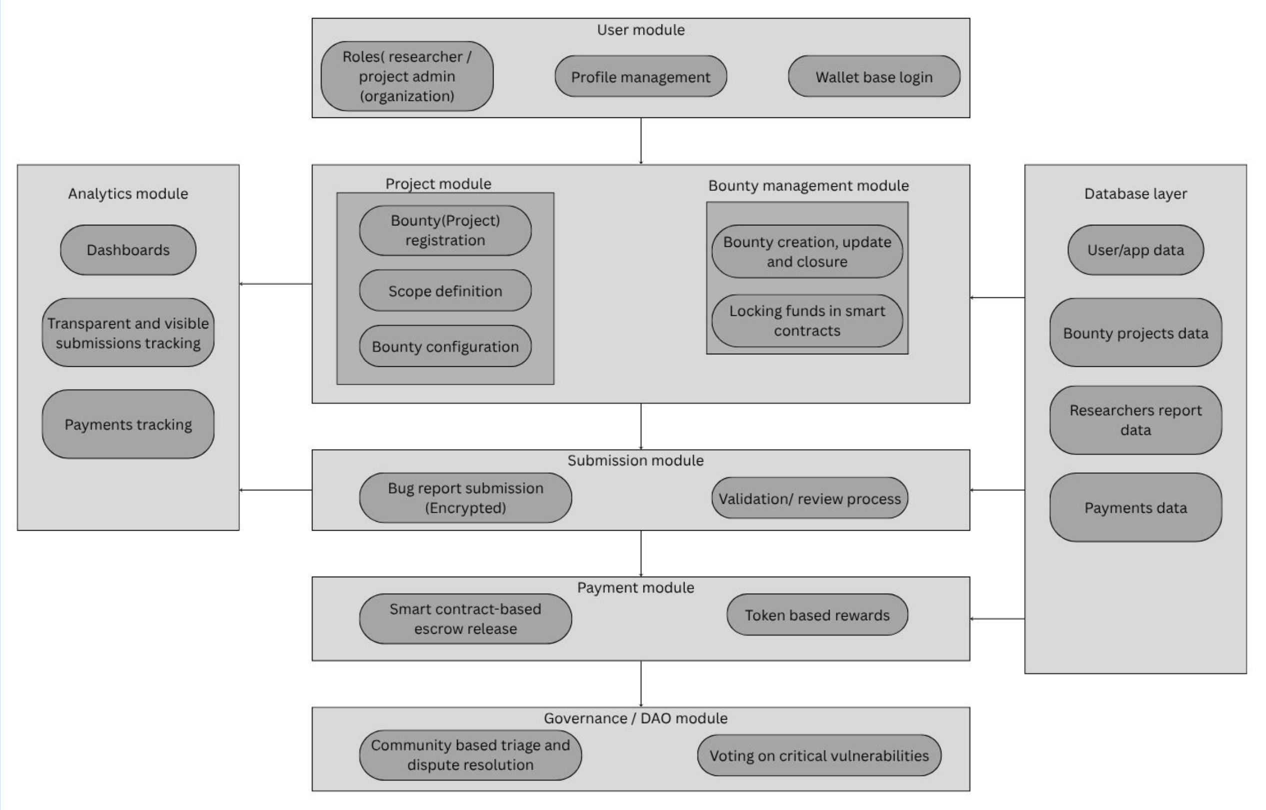
Problem Definition

Traditional bug bounty platforms rely heavily on centralized trust and manual policies, which often lead to inefficiencies and researcher dissatisfaction. Verification of submitted reports is typically slow and lacks transparency, resulting in delays and friction in reward distribution. Moreover, arbitrary reward caps frequently undervalue critical exploits, discouraging skilled researchers from active participation. Disputes, inconsistencies in payout decisions, and custodial risks further erode researcher confidence. These limitations not only weaken trust between organizations and security researchers but also increase the risk of undisclosed vulnerabilities remaining unpatched, leaving systems exposed to potential threats.

Block Diagram



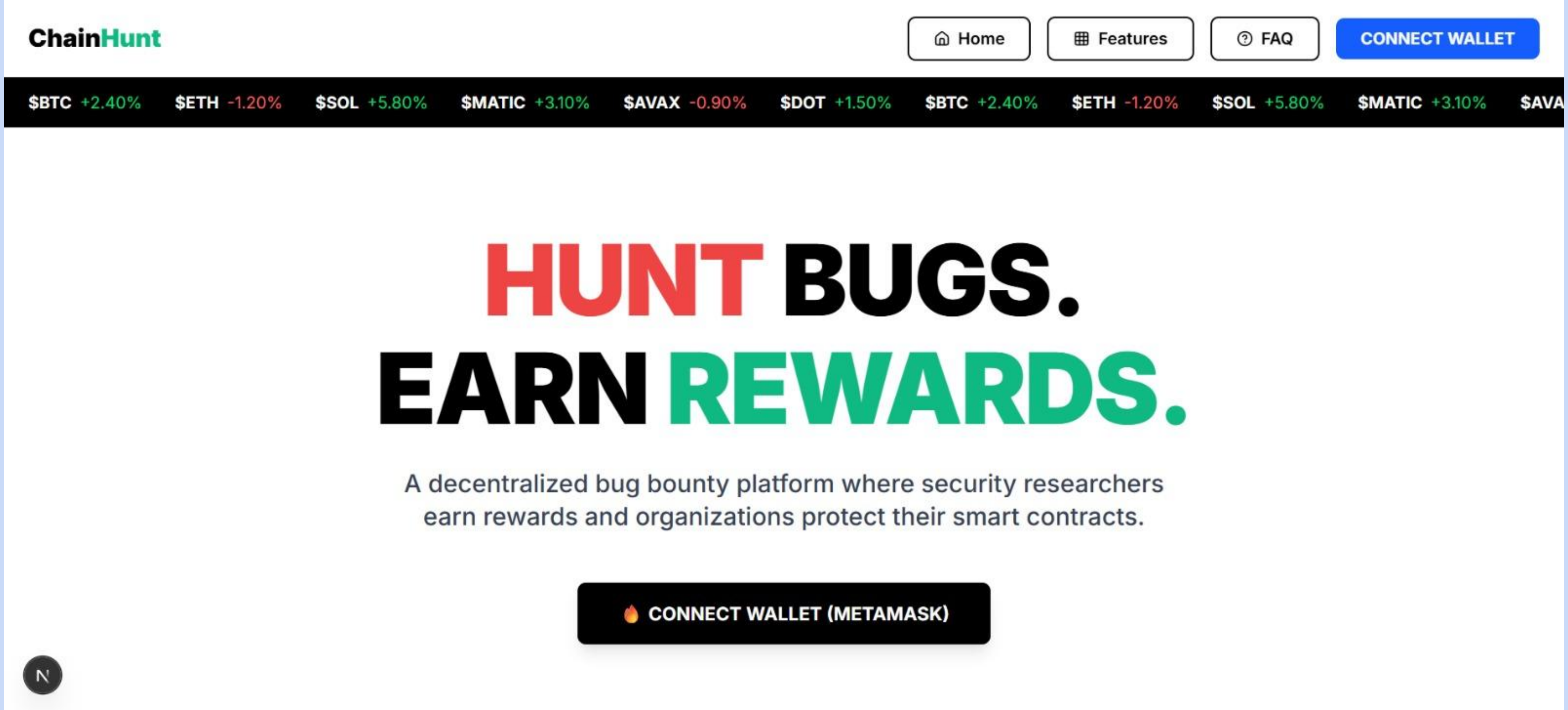
Modular Diagram



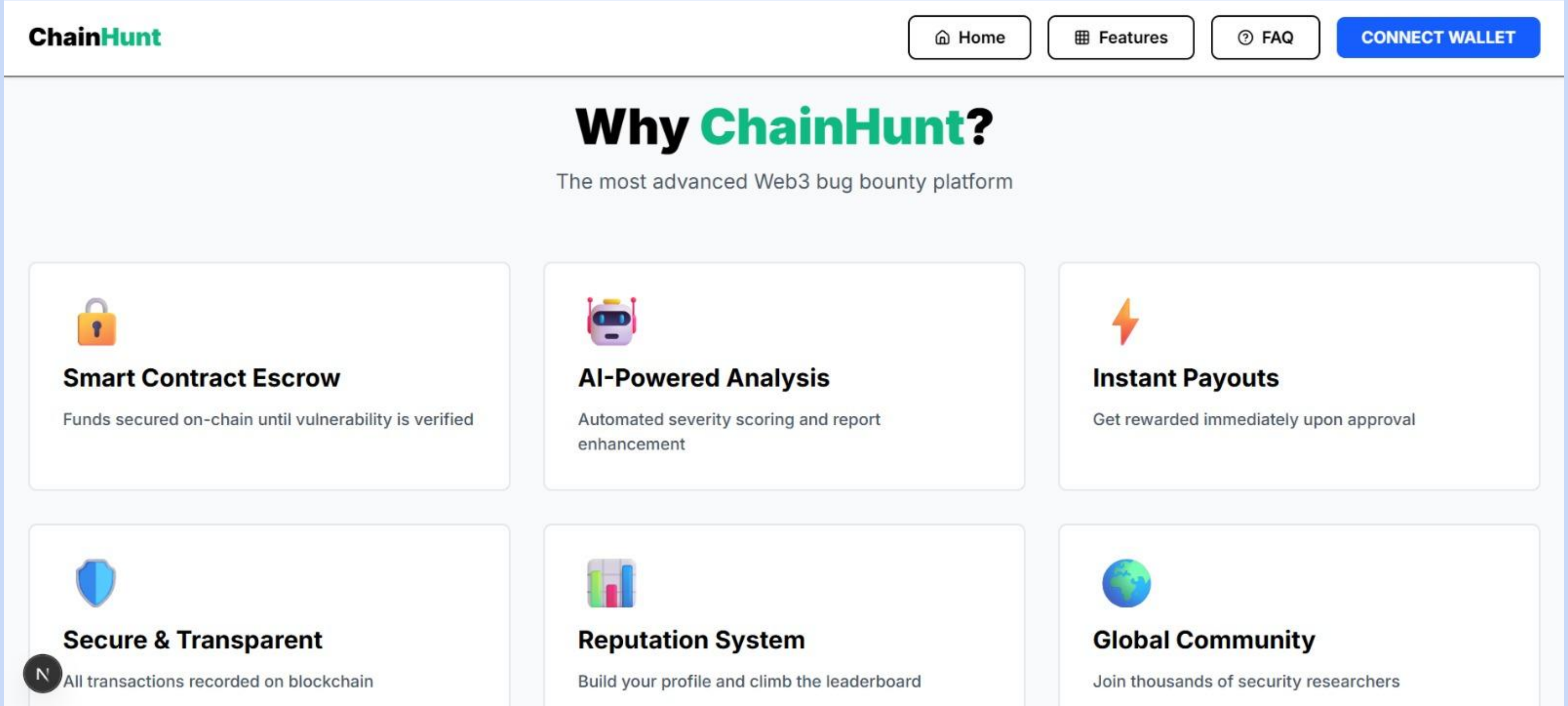
Implementation Details

- **Bounty Creation**
  - Owner drafts bounty with tiers & deadlines, Funds escrow smart contract on **Solidity chain**.
- **Submission**
  - Researcher prepares and encrypts report (client-side).
  - Report stored on **IPFS**; metadata and pointers stored in **PostgreSQL** via backend.
- **Validation & Triage**
  - Backend (Express + Prisma) validates submission format, Owner reviews securely through auditing service.
- **Decision & Payout**
  - On acceptance, **Solana contract releases payout** to researcher's wallet.
  - Optional dispute handled via off-chain arbitration + contract hooks.
- **Settlement & Reputation**
  - Smart contract emits payout event.
  - Backend services update researcher reputation, logs, and notifications.

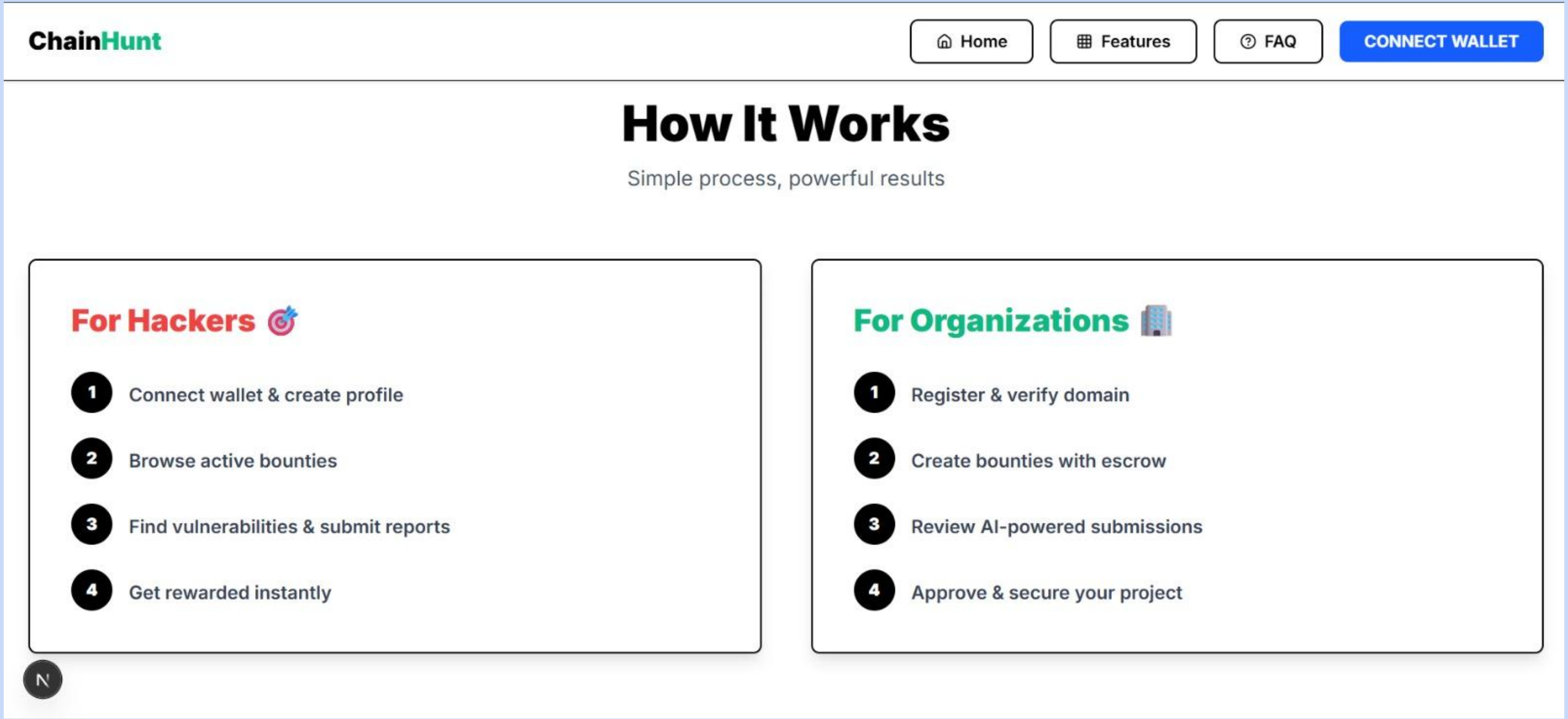
Implementation Screenshots



Implementation Screenshots



Implementation Screenshots



Implementation Screenshots

Next Work Plan

- **Notifications Service** → real-time updates using **WebSocket** (authenticated with JWT).
- **Caching & Optimization** → Redis for sessions, caching bounty listings, profile lookups.
- **Monitoring & Logging** → Prometheus + Grafana for metrics, alerts, dashboards.
- **Storage Integration** → IPFS for decentralized storage of reports & evidence.
- **Infra** → Dockerize all services, orchestrate with AWS ECS/Kubernetes.
- **Research paper drafting** → Formal documentation of system design and implementation details following publication standards.

References

[1] Outpost24. (2022). What are Bug Bounty Programs? Link
[2] Hoffman, E., Grishchenko, I., & Schär, F. (2021). Bountychain: A decentralized bug bounty platform. In International Conference on Blockchain Technology (Springer). Link
[3] Coindesk. (2018). Gitcoin and Bounties Network: Blockchain-based freelance and bug bounty markets. Link
[4] USENIX Security Symposium. (2018). The Hydra Framework: Incentivizing responsible vulnerability disclosure with smart contracts. Link
[5] Lido Research Forum. (2022). Hats.finance: DAO-managed bug bounty vaults. Link
[6] Greenberg, A. (2019). Apple vs. exploit brokers: Why capped bug bounties fall short. USENIX/WIRED discussion. Link
[7] Stock, B., & Johns, M. (2019). The economics of bug bounty programs and researcher incentives. Journal of Cybersecurity.
[8] Immunefi. (2021). State of Web3 Bug Bounties. Link